AI Supply Chain Guardian audit

Request: 92bebc7a3cf042618abc6997724debf6

Status: final | Score: 62.25 | Decision: review

Trust score 62.25/100 (review). Top risks: high sql_injection from code_security in db.py (db.py:38) (risk 21.2); medium prompt_injection_uncertain from prompt_injection in db.py (db.py:33) (risk 5.5); medium prompt_injection_uncertain from prompt_injection in db.py (db.py:42) (risk 5.5).

Coverage: full

code_security: fail (full)

high - db.py:38: Dynamic SQL text reaches execution; bound values do not sanitize the query text itself.

Remediation: Use parameterized queries instead of string concatenation: cursor.execute("SELECT * FROM users WHERE name = %s", (user_input,)) Never build SQL by concatenating or f-string-formatting raw input.

secret_detection: pass (full)

prompt_injection: warn (full)

medium - db.py:33: prompt_injection_uncertain

medium - db.py:42: prompt_injection_uncertain

medium - db.py:51: prompt_injection_uncertain

Scoring method: weighted

Safety overrides and uncertainty floors remain authoritative. Synthetic-trained models require independent validation. Provisional reports can change.